

D828

Legal Issues in Information Security

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	_____	

Items

1.

A 20-person startup based in a converted warehouse sells a step-counting and sleep-tracking app directly to consumers. It has no contracts with health plans or providers. Does HIPAA govern the app's user data?

- A. Yes, because HIPAA covers all health-related data.
- B. Generally no, because it is neither a covered entity nor a business associate, though consumer-protection and state privacy laws can still apply.
- C. Yes, because the company has more than 15 employees.
- D. Only if it stores the data in the cloud.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2. [TRANSFER — reversed stem / different variable]

A clinic plans to send patient records to an outside billing company that will process claims on its behalf. What does HIPAA require before the clinic shares the records?

- A. Written patient authorization for every record.
- B. The billing company must first become a covered entity.
- C. A signed business associate agreement.
- D. Nothing, because the billing company is not a covered entity.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3.

A US online retailer with a warehouse in Ohio ships orders to customers in France and Germany and markets to them in their languages. It has no office in the EU, and its chief executive has 20 years of retail experience. Does GDPR apply to its handling of those customers' data?

- A. Only for customers who are EU citizens.
- B. No, because it has no EU office.
- C. Yes, because it offers goods to people in the EU.
- D. Only if its servers are in the EU.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4. [TRANSFER — reversed stem / different variable]

A company subject to GDPR becomes aware at 9:00 a.m. Monday of a personal data breach likely to put individuals at risk. By when must it notify the supervisory authority, absent a justified delay?

- A.** Only once the full investigation is complete, however long it takes.
- B.** 9:00 a.m. Thursday
- C.** 9:00 a.m. the following Monday
- D.** 9:00 a.m. Wednesday

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5.

A regional mortgage lender with 11 branches and a newly refreshed logo must protect customers' nonpublic personal information and send them privacy notices. Which US law most directly requires this?

- A.** HIPAA
- B.** Sarbanes-Oxley (SOX)
- C.** FERPA
- D.** The Gramm-Leach-Bliley Act (GLBA)

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6.

Auditors of a publicly traded software company, whose headquarters spans three buildings, are testing who can change entries in the general ledger system and whether access reviews happen quarterly. Which law most directly drives this testing?

- A.** Sarbanes-Oxley (SOX)
- B.** SOX, but only for accounting staff, not IT access.
- C.** GLBA
- D.** PCI DSS

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7.

The owner of a coffee chain with 45 locations accepts credit cards and asks whether PCI DSS is a federal law. Which statement is correct?

- A. It does not apply to chains with fewer than 50 locations.
- B. It is a federal law enforced by the FTC.
- C. It applies only to banks.
- D. It is an industry standard enforced through contracts with card brands and banks, and it applies to any business that handles card data.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8. [TRANSFER — reversed stem / different variable]

Which organization must comply with PCI DSS?

- A. A small online shop that processes card payments on its own server
- B. A business that accepts only cash and checks
- C. Only merchants with over 6 million card transactions a year
- D. A hospital records system that holds no card data

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9.

Before buying a smaller payroll firm, a company with a 30-year history reviews the target's security audit reports, breach history, and vendor contracts. Which concept does this review illustrate?

- A. A compliance certification
- B. Negligence
- C. Due diligence
- D. Due care

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10. [TRANSFER — reversed stem / different variable]

After an assessment finds weak encryption, a company patches its systems and enforces strong encryption on all laptops. What does this action show?

- A. Due care
- B. Neither; only a court can show due care.
- C. Downstream liability
- D. Due diligence

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

A university IT office serving 12,000 students issues a document stating: all university laptops must use full-disk encryption with AES-256 and lock after 10 minutes idle. Which type of document is this?

- A.** A procedure
- B.** A standard
- C.** A policy
- D.** A guideline

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12.

A health billing firm with 300 staff found that 22% of employees clicked a test phishing email. Its only training is a 10-minute video at hire. The firm just moved into a new building. What is the best change to its program?

- A.** Fire anyone who clicks a test email.
- B.** Train only the IT staff more deeply.
- C.** Replace the video with one long session, since one session is always enough.
- D.** Ongoing, role-based training for all staff, with periodic simulated phishing and tracked results.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer B Concept 1

A ~~20-person startup based in a converted warehouse~~ sells a step-counting and sleep-tracking app directly to consumers. It has no contracts with health plans or providers. Does HIPAA govern the app's user data?

Target word: does HIPAA apply **Decides:** Not a covered entity or business associate.

A	Absolute language	HIPAA covers specific entities, not every holder of health data.
B	Correct	HIPAA follows who holds the data, not the type of data alone.
C	Camouflage	Headcount does not decide HIPAA coverage.
D	Adjacent category	Storage location does not decide whether HIPAA applies.

2. Answer C Concept 1 • transfer

A clinic plans to send patient records to an outside billing company that will process claims on its behalf. What does HIPAA require before the clinic shares the records?

Target word: reverse: from the relationship to the requirement **Decides:** The billing company is a business associate.

A	Adjacent category	Payment activities are allowed without authorization when a BAA is in place.
B	Confusion set	Vendors become business associates, not covered entities.
C	Correct	Covered entities must have a BAA with vendors that handle PHI for them.
D	Dropped element	Drops the business associate rule.

3. Answer C Concept 2

A US online retailer ~~with a warehouse in Ohio~~ ships orders to customers in France and Germany and markets to them in their languages. It has no office in the EU, and ~~its chief executive has 20 years of retail experience.~~ Does GDPR apply to its handling of those customers' data?

Target word: territorial scope **Decides:** It offers goods to people in the EU.

A	Confusion set	GDPR protects people in the EU, not citizens as such.
B	Dropped element	Drops the targeting rule, which applies without an establishment.
C	Correct	GDPR reaches non-EU organizations that target people in the EU.
D	Adjacent category	Server location does not decide scope.

4. Answer B Concept 2 • transfer

A company subject to GDPR becomes aware at 9:00 a.m. Monday of a personal data breach likely to put individuals at risk. By when must it notify the supervisory authority, absent a justified delay?

Target word: solve for the deadline **Decides:** 72 hours from awareness.

A	Absolute language	Notice is due within 72 hours; details can follow in phases.
B	Correct	Monday 9:00 a.m. + 72 hours.
C	Wrong stem number	Counts a week, not 72 hours.
D	Confusion set	48 hours; not the GDPR window.

5. Answer D Concept 3

A regional mortgage lender ~~with 11 branches and a newly refreshed logo~~ must protect customers' nonpublic personal information and send them privacy notices. Which US law most directly requires this?

Target word: which law **Decides:** A financial institution handling consumer financial data.

A	Confusion set	Covers health information held by covered entities.
B	Adjacent category	Concerns financial reporting by public companies, not consumer privacy.
C	Confusion set	Covers student education records.
D	Correct	GLBA's Safeguards and Privacy Rules cover financial institutions.

6. Answer A Concept 4

Auditors of a publicly traded software company, ~~whose headquarters spans three buildings~~, are testing who can change entries in the general ledger system and whether access reviews happen quarterly. Which law most directly drives this testing?

Target word: which law **Decides:** Public company plus controls over financial reporting.

A	Correct	SOX requires assessed internal controls over financial reporting, including IT access.
B	Dropped element	IT general controls over financial systems are part of SOX scope.
C	Adjacent category	Protects consumer financial data at financial institutions.
D	Confusion set	An industry standard for cardholder data, not financial reporting.

7. Answer D Concept 5

The owner of a coffee chain ~~with 45 locations~~ accepts credit cards and asks whether PCI DSS is a federal law. Which statement is correct?

Target word: nature and reach of PCI DSS **Decides:** It is a contractual industry standard.

A	Camouflage	Location count does not decide applicability.
B	Confusion set	No federal statute creates PCI DSS.
C	Adjacent category	Merchants and service providers must comply.
D	Correct	PCI DSS is not a statute; merchant agreements make it binding.

8. Answer A Concept 5 • transfer

Which organization must comply with PCI DSS?

Target word: reverse: from the standard to who it covers **Decides:** Storing, processing, or transmitting cardholder data.

A	Correct	Any entity handling cardholder data is in scope.
B	Confusion set	No card data is handled.
C	Absolute language	Volume changes validation level, not whether compliance is required.
D	Adjacent category	No cardholder data, so PCI DSS does not apply to it.

9. Answer C Concept 6

Before buying a smaller payroll firm, a company ~~with a 30-year history~~ reviews the target's security audit reports, breach history, and vendor contracts. Which concept does this review illustrate?

Target word: name the concept **Decides:** Investigating and assessing risk before acting.

A	Adjacent category	A review for a deal is not a certification.
B	Inverted operation	Negligence is failing to act reasonably — the opposite.
C	Correct	Researching risk before a decision is due diligence.
D	Confusion set	Due care is taking protective action, not investigating.

10. Answer A Concept 6 • transfer

After an assessment finds weak encryption, a company patches its systems and enforces strong encryption on all laptops. What does this action show?

Target word: reverse: from action to concept **Decides:** Acting to protect.

A	Correct	Implementing reasonable protections is due care.
B	Absolute language	Organizations show due care through their actions.
C	Adjacent category	Concerns harm to third parties, not the act of fixing.
D	Confusion set	The assessment was diligence; the fix is care.

11. Answer B Concept 7

A university IT office ~~serving 12,000 students~~ issues a document stating: all university laptops must use full-disk encryption with AES-256 and lock after 10 minutes idle. Which type of document is this?

Target word: document type **Decides:** Specific, mandatory, measurable requirements.

A	Confusion set	Procedures give step-by-step instructions.
B	Correct	Standards set specific mandatory requirements that support a policy.
C	Adjacent category	Policies state high-level intent, not exact settings.
D	Inverted operation	Guidelines are optional; this is mandatory.

12. Answer D Concept 8

A health billing firm with 300 staff found that 22% of employees clicked a test phishing email. Its only training is a 10-minute video at hire. ~~The firm just moved into a new building.~~ What is the best change to its program?

Target word: effective awareness program **Decides:** One-time training and a high error rate.

A	Adjacent category	Discipline without training discourages reporting and does not build skill.
B	Dropped element	Drops the non-IT staff who are clicking.
C	Absolute language	Awareness fades without reinforcement.
D	Correct	Repeated, measured training changes behavior over time.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owled.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	4	
Wrong stem number	A figure copied from the prompt that is not the answer.	1	
Adjacent category	The right idea in the wrong bucket.	11	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	2	
Absolute language	Always, never, guarantee — where judgment applies.	5	
Confusion set	Every option is real; the test is exact role-matching.	11	
Camouflage	Answers a stem fact that was never the question.	2	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	HIPAA scope	HIPAA binds covered entities (providers, health plans, clearinghouses) and their business associates, which must sign a business associate agreement.	Assuming HIPAA covers any health-related data, such as a consumer fitness app.	Who holds the data and whether they work for a provider or plan.
2	GDPR reach and breach timing	GDPR applies to organizations anywhere that offer goods or services to, or monitor, people in the EU; notifiable breaches go to the supervisory authority within 72 hours of awareness.	Thinking GDPR needs an EU office, or that it follows citizenship.	A non-EU company with EU customers, or a breach discovery time.
3	GLBA	The Gramm-Leach-Bliley Act requires financial institutions to protect customers' nonpublic personal information and give privacy notices.	Mixing it up with HIPAA or SOX.	Lenders, banks, insurers, and consumer financial data.
4	SOX and internal controls	Sarbanes-Oxley requires public companies to maintain and assess internal controls over financial reporting, including IT access controls around financial systems.	Thinking SOX is only an accounting matter with no IT role.	"Publicly traded" and "financial reporting."
5	PCI DSS is a contractual standard	PCI DSS is an industry standard enforced through card-brand and acquirer contracts; it applies to any entity that stores, processes, or transmits cardholder data.	Calling it a federal law or thinking only large merchants must comply.	Credit card acceptance of any size.
6	Due diligence vs. due care	Due diligence is investigating and understanding risk; due care is acting reasonably to address it.	Swapping the two terms.	Researching and assessing vs. actually implementing protections.
7	Policy, standard, procedure, guideline	A policy states intent, a standard sets specific mandatory requirements, a procedure gives step-by-step instructions, and a guideline is an optional recommendation.	Calling any mandatory rule a policy.	A specific, measurable "must" (standard) vs. steps (procedure).
8	Security awareness training	Effective awareness training is ongoing, role-based, for all staff, and measured over time.	A one-time session, or training only IT staff.	A high human-error rate and a one-time or IT-only program.

Course scope (public description): Legal Issues in Information Security provides learners with exposure to the laws and ethical issues of cybersecurity and the importance of compliance. Learners explore the fundamental standards, frameworks, and best practices of data privacy and data privacy protection. Next, learners are exposed to the legal requirements and frameworks necessary to ensure organizational policies and procedures are compliant. Finally, learners will analyze legal requirements and best practices for protecting organizations from security incidents and understand the training and education necessary for creating employee awareness.